

Konformitätsbericht

Beispiel-Betreiber GmbH · Wesentliche Einrichtung · Stand 6.10.2026

BSI-Gesetz in der Fassung des NIS2UmsuCG (BGBl. 2025 I Nr. 301) — nationales Umsetzungsgesetz; seine Anforderungen bewertet dieses Modul noch nicht

ITORO-Selbstbewertungswerkzeug — das Dokument stellt weder ein Audit noch eine Rechtsberatung dar.

Zusammenfassung für die Geschäftsleitung

STATUS DER EINRICHTUNG

Wesentliche Einrichtung

NIS-2-Richtlinie Artikel 3 Absatz 1 Buchstabe

(Anbieter öffentlicher elektronischer Kommunikationsnetze oder öffentlich zugänglicher elektronischer Kommunikationsdienste, der mindestens ein mittleres Unternehmen ist)

GRAD DER VORBEREITUNG

59%

Reifegrad 2.4 bei Zielstufe 4

FORMALE PFLICHTEN

8/16

3 nicht erfüllt, 5 in Arbeit

Nächste gesetzliche Fristen

- **17.10.2027** (in 376 Tagen) — Erste Überprüfung der Richtlinie durch die Kommission

Größte Lücken

1. Cyberhygiene und Schulungen — Reifegrad 2.0 gegenüber Ziel 4, Priorität **kritisch**
2. 7. Konzepte und Verfahren zur Bewertung der Wirksamkeit von Risikomanagementmaßnahmen im Bereich der Cybersicherheit (Artikel 21 Absatz 2 Buchstabe f der Richtlinie (EU) 2022/2555) — Reifegrad 2.0 gegenüber Ziel 4, Priorität **kritisch**
3. 9. Kryptografie (Artikel 21 Absatz 2 Buchstabe h der Richtlinie (EU) 2022/2555) — Reifegrad 2.0 gegenüber Ziel 4, Priorität **kritisch**
4. 2. Konzept für das Risikomanagement (Artikel 21 Absatz 2 Buchstabe a der Richtlinie (EU) 2022/2555) — Reifegrad 2.2 gegenüber Ziel 4, Priorität **hoch**
5. 4. Betriebskontinuitäts- und Krisenmanagement (Artikel 21 Absatz 2 Buchstabe c der Richtlinie (EU) 2022/2555) — Reifegrad 2.2 gegenüber Ziel 4, Priorität **hoch**

Die Behörden erhalten die Befugnis zur Verhängung von Geldbußen ab **17.10.2024** (**NIS-2-Richtlinie** Artikel 41 Absatz 1). Ab wann die nationale Behörde Geldbußen verhängen kann, bestimmt das Umsetzungsgesetz — dieses Modul kennt es nicht. Das finanzielle Risiko ist hier daher nicht datiert, die Umsetzungspflichten ergeben sich aber aus dem nationalen Recht ab dessen Inkrafttreten.

Einrichtung

Wie diese Obergrenze entsteht — zwei getrennte Schritte

1. Die Mindestobergrenze setzt die Richtlinie

Verglichen werden zwei Werte: ein Festbetrag in Euro und ein Prozentsatz des gesamten weltweiten Jahresumsatzes des Unternehmens im vorangegangenen Geschäftsjahr. Der höhere ist die Obergrenze, die der Mitgliedstaat mindestens vorsehen muss. Das nationale Recht kann sie anheben.

NIS-2-Richtlinie Artikel 34 Absatz 4 und 5

2. Den Betrag innerhalb der Obergrenze bestimmt die nationale Behörde

Die Geldbuße muss je nach den Umständen des Einzelfalls wirksam, verhältnismäßig und abschreckend sein. Die Behörde berücksichtigt mindestens die Kriterien des Artikels 32 Absatz 7: Schwere und Dauer des Verstoßes, frühere Verstöße, Schäden, Vorsatz, Abhilfemaßnahmen und Zusammenarbeit.

NIS-2-Richtlinie Artikel 34 Absatz 1 und 3

Die Obergrenze kann den Jahresumsatz um ein Vielfaches übersteigen — sie ist eine Obergrenze und kein zu erwartender Betrag. Nationale Mindestbeträge, Zwangsgelder und das Bemessungsverfahren bestimmt das Gesetz des Mitgliedstaats.

Die gesetzliche Obergrenze der Geldbuße beträgt **10.000.000 EUR**. Der Festbetrag überwiegt: 10 Mio. EUR sind höher als 2 % des Umsatzes.

- Prozentvariante: 480.000 EUR
- Betragsvariante: 10.000.000 EUR
- Gesetzliches Minimum: 0 EUR

Die Obergrenzen nach Artikel 34 Absätze 4 und 5 sind Mindestwerte („mindestens“) — das nationale Recht kann höhere vorsehen. Beträge in Euro, ohne Umrechnung in die Landeswährung.

Bemessung der Geldbuße — **NIS-2-Richtlinie** Artikel 34 Absatz 3 und Artikel 32 Absatz 7

Bei der Entscheidung, ob eine Geldbuße verhängt wird und in welcher Höhe, sind in jedem Einzelfall mindestens die in Artikel 32 Absatz 7 genannten Elemente gebührend zu berücksichtigen.

Kriterien aus Artikel 32 Absatz 7 der Richtlinie:

- Schwere des Verstoßes und Bedeutung der verletzten Vorschriften — als schwerwiegend gelten in jedem Fall: wiederholte Verstöße, Nichtmeldung oder Nichtbehebung erheblicher Sicherheitsvorfälle, Nichtbehebung von Mängeln entgegen verbindlichen Anweisungen, Behinderung von Prüfungen oder Überwachung, Übermittlung falscher oder grob ungenauer Informationen
- czas trwania naruszenia
- einschlägige frühere Verstöße der Einrichtung
- verursachte materielle und immaterielle Schäden, einschließlich finanzieller Verluste, Auswirkungen auf andere Dienste und Zahl der betroffenen Nutzer
- Vorsätzlichkeit oder Fahrlässigkeit der Handlung
- Maßnahmen zur Verhinderung oder Minderung der Schäden
- Einhaltung genehmigter Verhaltenskodizes oder Zertifizierungsverfahren
- Umfang der Zusammenarbeit mit den zuständigen Behörden

Die Richtlinie sieht ein Absehen von der Geldbuße nicht ausdrücklich vor — ob und wann dies möglich ist, entscheidet das nationale Recht.

- Die Mitgliedstaaten können Zwangsgelder vorsehen, um die Beendigung eines Verstoßes zu erzwingen. Die Höhe bestimmt das nationale Recht.
- Die Richtlinie sieht keine gesonderte Geldbuße für einen qualifizierten Verstoß vor — das ist eine Konstruktion des nationalen Rechts einiger Staaten.

Leiter der Einrichtung

Rechtsakt	Grundlage	Behörde	Obergrenze
Richtlinie (EU) 2022/2555	NIS-2-Richtlinie Artikel 20 Absatz 1	Zuständige Behörde des Mitgliedstaats	0 EUR

- Das Leitungsorgan billigt die Risikomanagementmaßnahmen im Bereich der Cybersicherheit (Artikel 20 Absatz 1).
- Das Leitungsorgan überwacht die Umsetzung dieser Maßnahmen (Artikel 20 Absatz 1).
- Die Mitglieder des Leitungsorgans nehmen regelmäßig an Schulungen teil (Artikel 20 Absatz 2).
- Gegenüber einer wesentlichen Einrichtung kann die Behörde ein vorübergehendes Verbot der Wahrnehmung von Leitungsaufgaben beantragen (Artikel 32 Absatz 5 Buchstabe b).

Die Einrichtung übt eine Telekommunikationstätigkeit aus — die Haftung der Leitungsperson richtet sich nach nationalem Recht

Die Behörden erhalten die Befugnis zur Verhängung von Geldbußen ab **17.10.2024** (**NIS-2-Richtlinie** Artikel 41 Absatz 1). Ab wann die nationale Behörde Geldbußen verhängen kann, bestimmt das Umsetzungsgesetz — dieses Modul kennt es nicht. Die Umsetzungspflichten ergeben sich aus dem nationalen Recht ab dessen Inkrafttreten.

2.4
Rozwijany
GESAMTREIFEGRAD

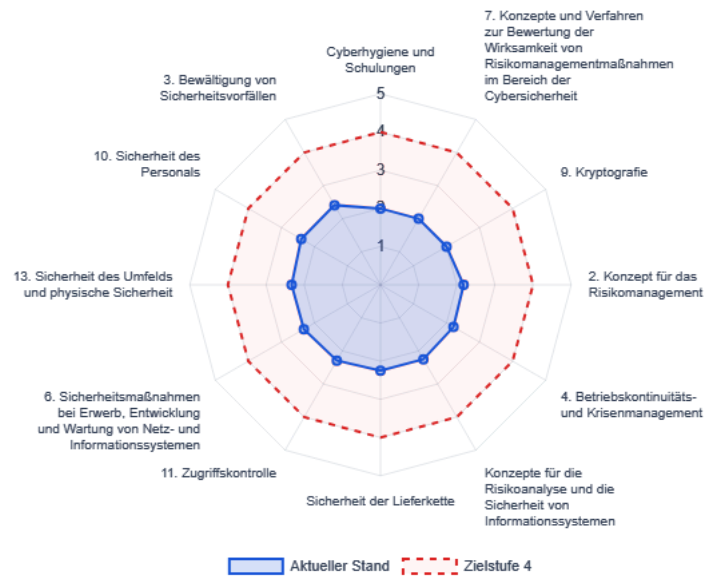
59%
Ziel: Stufe 4
KONFORMITÄTSGRAD

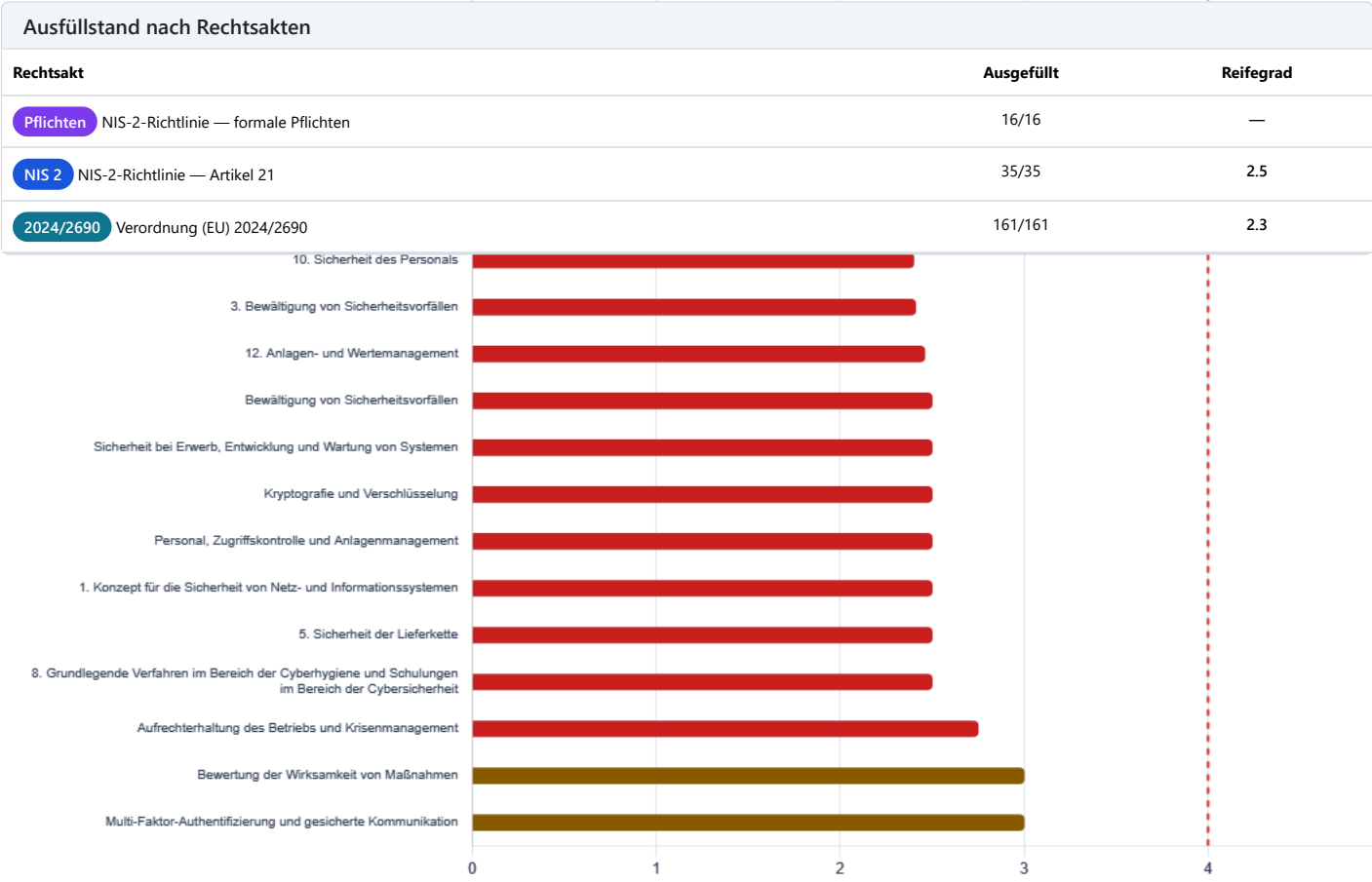
1.6
bis zur Zielstufe
DURCHSCHNITTliche LÜCKE

212/212
100% ausgefüllt
ANTWORTEN

Reifegradprofil

12 Bereiche mit der größten Lücke von 23





Lückenanalyse						
Bereich		Aktuell	Ziel	Lücke	Priorität	Ausfüllstand
Cyberhygiene und Schulungen		2.0	4	2.0	Kritisch	3/3
NIS-2-Richtlinie	Artikel 21 Absatz 2 Buchstabe g					
NIS-2-Richtlinie	Artikel 20 Absatz 2					
7. Konzepte und Verfahren zur Bewertung der Wirksamkeit von Risikomanagementmaßnahmen im Bereich der Cybersicherheit (Artikel 21 Absatz 2 Buchstabe f der Richtlinie (EU) 2022/2555)		2.0	4	2.0	Kritisch	3/3
VO 2024/2690	Anhang, Abschnitt 7					
9. Kryptografie (Artikel 21 Absatz 2 Buchstabe h der Richtlinie (EU) 2022/2555)		2.0	4	2.0	Kritisch	3/3
VO 2024/2690	Anhang, Abschnitt 9					
2. Konzept für das Risikomanagement (Artikel 21 Absatz 2 Buchstabe a der Richtlinie (EU) 2022/2555)		2.2	4	1.8	Hoch	11/11
VO 2024/2690	Anhang, Abschnitt 2					
4. Betriebskontinuitäts- und Krisenmanagement (Artikel 21 Absatz 2 Buchstabe c der Richtlinie (EU) 2022/2555)		2.2	4	1.8	Hoch	14/14
VO 2024/2690	Anhang, Abschnitt 4					
Konzepte für die Risikoanalyse und die Sicherheit von Informationssystemen		2.3	4	1.8	Hoch	4/4
NIS-2-Richtlinie	Artikel 21 Absatz 2 Buchstabe a					
Sicherheit der Lieferkette		2.3	4	1.8	Hoch	4/4
NIS-2-Richtlinie	Artikel 21 Absatz 2 Buchstabe d					
NIS-2-Richtlinie	Artikel 21 Absatz 3					
11. Zugriffskontrolle (Artikel 21 Absatz 2 Buchstaben i und j der Richtlinie (EU) 2022/2555)		2.3	4	1.7	Hoch	21/21
VO 2024/2690	Anhang, Abschnitt 11					
6. Sicherheitsmaßnahmen bei Erwerb, Entwicklung und Wartung von Netz- und Informationssystemen (Artikel 21 Absatz 2 Buchstabe e der Richtlinie (EU) 2022/2555)		2.3	4	1.7	Hoch	31/31
VO 2024/2690	Anhang, Abschnitt 6					
13. Sicherheit des Umfelds und physische Sicherheit (Artikel 21 Absatz 2 Buchstaben c, e und i der Richtlinie (EU) 2022/2555)		2.3	4	1.7	Hoch	9/9
VO 2024/2690	Anhang, Abschnitt 13					
10. Sicherheit des Personals (Artikel 21 Absatz 2 Buchstabe i der Richtlinie (EU) 2022/2555)		2.4	4	1.6	Hoch	10/10
VO 2024/2690	Anhang, Abschnitt 10					
3. Bewältigung von Sicherheitsvorfällen (Artikel 21 Absatz 2 Buchstabe b der Richtlinie (EU) 2022/2555)		2.4	4	1.6	Hoch	22/22
VO 2024/2690	Anhang, Abschnitt 3					
12. Anlagen- und Wertemanagement (Artikel 21 Absatz 2 Buchstabe i der Richtlinie (EU) 2022/2555)		2.5	4	1.5	Hoch	13/13
VO 2024/2690	Anhang, Abschnitt 12					
Bewältigung von Sicherheitsvorfällen		2.5	4	1.5	Hoch	4/4
NIS-2-Richtlinie	Artikel 21 Absatz 2 Buchstabe b					
Sicherheit bei Erwerb, Entwicklung und Wartung von Systemen		2.5	4	1.5	Hoch	4/4
NIS-2-Richtlinie	Artikel 21 Absatz 2 Buchstabe e					
Kryptografie und Verschlüsselung		2.5	4	1.5	Hoch	2/2
NIS-2-Richtlinie	Artikel 21 Absatz 2 Buchstabe h					
Personal, Zugriffskontrolle und Anlagenmanagement		2.5	4	1.5	Hoch	4/4
NIS-2-Richtlinie	Artikel 21 Absatz 2 Buchstabe i					
1. Konzept für die Sicherheit von Netz- und Informationssystemen (Artikel 21 Absatz 2 Buchstabe a der Richtlinie (EU) 2022/2555)		2.5	4	1.5	Hoch	8/8
VO 2024/2690	Anhang, Abschnitt 1					
5. Sicherheit der Lieferkette (Artikel 21 Absatz 2 Buchstabe d der Richtlinie (EU) 2022/2555)		2.5	4	1.5	Hoch	8/8
VO 2024/2690	Anhang, Abschnitt 5					
8. Grundlegende Verfahren im Bereich der Cyberhygiene und Schulungen im Bereich der Cybersicherheit (Artikel 21 Absatz 2 Buchstabe g der Richtlinie (EU) 2022/2555)		2.5	4	1.5	Hoch	8/8
VO 2024/2690	Anhang, Abschnitt 8					
Aufrechterhaltung des Betriebs und Krisenmanagement		2.8	4	1.3	Mittel	4/4
NIS-2-Richtlinie	Artikel 21 Absatz 2 Buchstabe c					
Bewertung der Wirksamkeit von Maßnahmen		3.0	4	1.0	Mittel	3/3
NIS-2-Richtlinie	Artikel 21 Absatz 2 Buchstabe f					

Bereich	Aktuell	Ziel	Lücke	Priorität	Ausfüllstand
Multi-Faktor-Authentifizierung und gesicherte Kommunikation	3.0	4	1.0	Mittel	3/3
NIS-2-Richtlinie Artikel 21 Absatz 2 Buchstabe j					

Rechtsrisikoregister — nicht erfüllte Pflichten			
Pflicht	Grundlage		Bußgeldrisiko
Ist die Einrichtung DNS-Diensteanbieter, TLD-Namenregister, Cloud-Anbieter, Rechenzentrum, CDN, Anbieter verwalteter Dienste, Online-Marktplatz, Suchmaschine oder soziales Netzwerk — hat sie die zusätzlichen Daten nach Artikel 27 übermittelt, einschließlich der Anschrift ihrer Hauptniederlassung in der Union? Registrierungsdaten für die Liste der Einrichtungen	NIS-2-Richtlinie	Artikel 27 Absatz 2	— Artikel 34
Ist die Einrichtung ein Vertrauensdiensteanbieter — meldet sie erhebliche Sicherheitsvorfälle innerhalb von 24 Stunden nach Kenntniserlangung? Meldung erheblicher Sicherheitsvorfälle	NIS-2-Richtlinie	Artikel 23 Absatz 4 Unterabsatz 2	24 godziny Artikel 34
Ist die wesentliche Einrichtung auf eine Sicherheitsprüfung durch die Behörde oder eine unabhängige Stelle auf eigene Kosten vorbereitet? Bereitschaft für Aufsichtsmaßnahmen	NIS-2-Richtlinie	Artikel 32 Absatz 2 Buchstabe b–c i Absatz 3	— Artikel 32 Absatz 4

Gesetzlicher Kalender			
Datum	Ereignis	Grundlage	Verbleibend
16.1.2023	Inkrafttreten der NIS-2-Richtlinie Am zwanzigsten Tag nach der Veröffentlichung im Amtsblatt.	NIS-2-Richtlinie Artikel 45	in Kraft
17.10.2024	Frist zur Umsetzung der Richtlinie Bis zu diesem Datum sollten die Mitgliedstaaten nationale Vorschriften erlassen und veröffentlichen.	NIS-2-Richtlinie Artikel 41 Absatz 1	in Kraft
18.10.2024	Anwendung der nationalen Vorschriften und Aufhebung von NIS 1 Ab diesem Datum wenden die Staaten die Umsetzungsvorschriften an; die Richtlinie (EU) 2016/1148 wird aufgehoben.	NIS-2-Richtlinie Artikel 41 Absatz 1 und Artikel 44	in Kraft
7.11.2024	Anwendung der Verordnung (EU) 2024/2690 Die Durchführungsverordnung gilt unmittelbar ab dem zwanzigsten Tag nach der Veröffentlichung.	VO 2024/2690 Artikel 16	in Kraft
17.4.2025	Liste der wesentlichen und wichtigen Einrichtungen Bis zu diesem Datum erstellen die Mitgliedstaaten die Liste; die Einrichtungen übermitteln den Behörden ihre Registrierungsdaten.	NIS-2-Richtlinie Artikel 3 Absatz 3 und 4	abgelaufen
17.10.2027	Erste Überprüfung der Richtlinie durch die Kommission Die Kommission überprüft die Funktionsweise der Richtlinie und erstattet Bericht.	NIS-2-Richtlinie Artikel 40	376 Tage

Schwellenwerte für einen erheblichen Sicherheitsvorfall

Für die folgenden Rollen ergeben sich die Schwellenwerte unmittelbar aus der Verordnung (EU) 2024/2690 und gelten seit dem 7. November 2024.

Anbieter von Rechenzentrumsdiensten (Artikel 8)

Das strengste Schwellenwertpaket der gesamten Verordnung. Für Rechenzentren gibt es KEINE 30-Minuten-Schwelle und KEINE Schwelle von 5 % / 1 Mio. Nutzern — jede vollständige Nichtverfügbarkeit des Dienstes und jede Verletzung des physischen Zugangs ist ein erheblicher Sicherheitsvorfall.

- **a)** Der Rechenzentrumsdienst ist vollständig nicht verfügbar — OHNE Zeitschwelle.
- **b)** Die Verfügbarkeit des Dienstes ist länger als 1 Stunde eingeschränkt — OHNE Prozent- oder Nutzerzahlschwelle.
- **c)** Integrität, Vertraulichkeit oder Authentizität von Daten sind infolge mutmaßlich böswilligen Handelns beeinträchtigt.
- **d)** Der physische Zugang zum vom Anbieter betriebenen Rechenzentrum ist verletzt.

Horizontale Kriterien (Artikel 3 Absatz 1) — die Erfüllung eines Kriteriums genügt

- **a)** Finanzieller Verlust — Der eingetretene oder mögliche finanzielle Verlust übersteigt 500 000 EUR oder 5 % des Gesamtjahresumsatzes der Einrichtung im vorangegangenen Geschäftsjahr — je nachdem, welcher Wert niedriger ist.
- **b)** Abfluss von Geschäftsgeheimnissen — Der Vorfall hat den Abfluss von Geschäftsgeheimnissen im Sinne von Artikel 2 Nummer 1 der Richtlinie (EU) 2016/943 verursacht oder kann ihn verursachen.
- **c)** Tod einer natürlichen Person — Der Vorfall hat den Tod einer natürlichen Person verursacht oder kann ihn verursachen.
- **d)** Erheblicher Gesundheitsschaden — Der Vorfall hat einen erheblichen Gesundheitsschaden einer natürlichen Person verursacht oder kann ihn verursachen.
- **e)** Unbefugter Zugriff — Es kam zu einem erfolgreichen, mutmaßlich böswilligen und unbefugten Zugriff auf Netz- und Informationssysteme, der schwerwiegende Betriebsstörungen verursachen kann.
- **f)** Wiederkehrende Vorfälle — Der Vorfall erfüllt die Kriterien des Artikels 4: er ist innerhalb von sechs Monaten mindestens zweimal aufgetreten, die Vorfälle haben dieselbe erkennbare Grundursache und erfüllen zusammen das Kriterium des finanziellen Verlusts nach Artikel 3 Absatz 1 Buchstabe a. Sie gelten zusammen als ein erheblicher Sicherheitsvorfall.
- **g)** Sektorspezifisches Kriterium — Der Vorfall erfüllt mindestens eines der sektorspezifischen Kriterien der Artikel 5 bis 14 der Verordnung.

Telekommunikationstätigkeit — die Schwellenwerte bestimmt das nationale Recht. Die Verordnung (EU) 2024/2690 gilt nicht für Anbieter öffentlicher elektronischer Kommunikationsnetze und -dienste. Für sie bestimmt das nationale Recht die Schwellenwerte für einen erheblichen Sicherheitsvorfall (Artikel 23 Absatz 11 der Richtlinie) — dieses Modul kennt sie nicht und nennt daher keine Zahlen.

Verlauf und Fortschritt

Es wurde noch keine Momentaufnahme gespeichert. Eine Momentaufnahme friert den aktuellen Stand der Bewertung mit Datum ein, sodass spätere Berichte den Fortschritt zeigen.

[Erste Momentaufnahme speichern](#)

Konformitätsbewertung nach der Richtlinie (EU) 2022/2555 des Europäischen Parlaments und des Rates (NIS 2) und der Durchführungsverordnung (EU) 2024/2690 der Kommission — gemeinsames Modul für Staaten, deren Modul zum nationalen Recht noch nicht fertig ist.

Stellt keine Rechtsberatung dar; alle Daten bleiben in diesem Browser oder lokal auf Ihrem Rechner.

Version 1.2.0 · 6. Oktober 2026 · [Änderungsliste](#)